

EVALUACIÓN DE RIESGOS DE SEGURIDAD

Informe de Endurecimiento de Red post-violación de datos

Autor: Ing. Mauro Alejandro Guadarrama García

Ingeniero en Sistemas Computacionales

Proyecto de Portafolio
Certificado Profesional de Ciberseguridad de Google
Junio 2026

Parte 1: Identificación de la Vulnerabilidad y Métodos de Endurecimiento

Vulnerabilidad Seleccionada: Los empleados de la organización comparten contraseñas y no se utiliza la autenticación multifactor (MFA).

Descripción del Riesgo: Esta es una vulnerabilidad crítica de Control de Acceso e Identidad (IAM). Si las credenciales son compartidas, la organización pierde la capacidad de auditar qué individuo específico realizó qué acción (no repudio). Además, sin MFA, un actor malicioso que obtenga estas credenciales compartidas tiene acceso inmediato y sin fricciones a sistemas sensibles y datos de clientes.

Métodos y Herramientas de Endurecimiento Recomendados:

- **Implementación Obligatoria de MFA (Autenticación Multifactor):** Utilizar aplicaciones de autenticación o tokens físicos para validar la identidad más allá de la contraseña.
- **Gestores de Contraseñas Corporativos (Password Managers):** Implementar una herramienta centralizada (como 1Password o Bitwarden a nivel empresarial) para generar, almacenar y rotar contraseñas fuertes de forma individual por empleado.
- **Políticas de Acceso Basado en Roles (RBAC) y Principio de Privilegio Mínimo:** Configurar los directorios activos para que cada empleado tenga credenciales únicas y solo acceda a la información estrictamente necesaria para su puesto.

Parte 2: Eficacia y Frecuencia de Implementación

¿Por qué es eficaz la técnica de Endurecimiento de seguridad recomendada?

La combinación de **MFA** y la **prohibición de compartir contraseñas a través de cuentas individuales (RBAC)** es altamente eficaz porque añade capas de defensa en profundidad. Si un atacante roba una contraseña (algo que el usuario sabe), la intrusión se detiene en el punto de inicio de sesión porque el atacante no posee el segundo factor (algo que el usuario tiene, como su teléfono). Además, al asignar cuentas individuales, se elimina la necesidad de compartir contraseñas para sistemas departamentales, permitiendo rastrear el origen de cualquier actividad sospechosa directamente a un usuario específico, lo cual es fundamental para una respuesta rápida a incidentes y auditorías de seguridad.

¿Con qué frecuencia debe implementarse la técnica de endurecimiento?

Estas medidas deben ser una **configuración de seguridad continua y permanente (24/7)** impuesta por las políticas del sistema.

- **MFA:** Debe requerirse en cada intento de inicio de sesión a los sistemas centrales.
- **Revisión de Accesos (Auditorías IAM):** El equipo de TI debe auditar los registros de acceso y revisar los permisos de usuario (RBAC) de manera **trimestral** (o inmediatamente cuando un empleado cambia de rol o abandona la empresa).
- **Educación y Concientización:** Las políticas sobre la gestión segura de contraseñas deben comunicarse y actualizarse mediante capacitaciones **anuales** a todo el personal.